通语客服技术接入指南

版本：2026-10-23-R3

1. 适用范围

说明业务网站、H5 与 App 如何嵌入通语聊天、关联已登录客户身份，以及如何安全管理宿主服务端密钥。具体可用接口受客户套餐、当前实例版本和服务端配置约束；商城集成与群管理 API 见附录。

2. 接入前请由平台方提供

- 客服服务 HTTPS 根地址 BASE_URL（不带末尾斜杠）。
- 本客户已启用的 inboxKey；它是公开入口 ID，不是凭证。
- 已启用的接入能力及本实例实际支持的身份签发请求头。
- 需嵌入 iframe 的宿主精确 HTTPS Origin。
- 登录接入、Webhook 或其他服务端调用是否已纳入套餐与实施范围。

接入参数由平台方在客户专属配置中提供；参数齐备后即可开展联调。本文 API_KEY_HEADER、MARKETPLACE_KEY_HEADER 分别代表客户配置单列明的租户密钥和商城密钥请求头名称，调用时替换为实际名称。

3. 匿名客户

可直接加载本客户的 H5 地址，或将聊天组件嵌入网站。匿名访问通过公开 inboxKey 识别入口，服务端 API 密钥保留在业务后端。

```
<script>
window.TongYuSettings = {
  endpoint: 'https://chat.example.com',
  inboxKey: 'public-inbox-key'
};
</script>
<script src="https://chat.example.com/widget.js"></script>
```

请将示例地址和入口标识替换为平台管理员针对本客户提供的真实配置。

4. 关联已登录的客户

宿主业务后端验证当前登录会话后申请身份票据，并从安全会话读取用户 ID 作为 externalId。后端保管具备 write 权限的租户 API Key，并使用双方确认过的请求头调用：

```
POST {BASE_URL}/api/v1/open/visitor-identity
<API_KEY_HEADER>: <SERVER_API_KEY>
Content-Type: application/json

{"inboxKey":"public-inbox-key","externalId":"stable-business-user-id","displayName":"客户昵称"}
```

标准身份票据 identityToken 有效期为 5 分钟。正式接入前须与平台方确认目标实例的接口版本、鉴权请求头及已开通能力，再完成联调。

将票据通过宿主后端的无缓存会话接口交给已登录客户页面，再由组件初始化：

```
window.TongYuSettings = {
  endpoint: 'https://chat.example.com',
  inboxKey: identity.inboxKey,
  identityToken: identity.identityToken
};
```

身份响应设置 Cache-Control: no-store；API Key 保存在业务后端，身份票据与登录 Token 通过安全消息交接并按会话管理，URL、持久存储及日志中的凭证信息应脱敏。用户切换账号时重新申请票据并销毁旧聊天状态。

5. iframe 与 WebView

iframe 的 parentOrigin 应设为宿主精确 Origin，并在发送 authenticate 之前校验消息来源和 contentWindow。服务端 CSP frame-ancestors、CORS 与 WebSocket Origin 应允许预先确认的来源。身份通信的信任范围使用精确 Origin。

App WebView 没有 iframe 父窗口，原生应用需使用所选 WebView 插件的双向消息桥传递 authenticate 和页面事件；身份交接采用对应插件的原生消息接口。麦克风、摄像头、自动播放、附件、返回按钮和键盘行为需要在目标设备验收。

6. 可靠性与错误处理

- 发送消息使用稳定 clientMessageId；网络重试沿用同一 ID。
- 消息按 sequence 排序；WebSocket 用于通知，断线后须调用消息历史 API 增量补拉。
- 票据过期时由业务后端重新签发；身份缺失、入口不匹配或权限不足应明确失败，重新认证后再继续访问。
- 处理 400/401/403/404 和 5xx；对网络与 5xx 有限重试，按响应状态处理失败并设置重试次数与间隔。
- 联系平台支持时提供请求路径、HTTP 状态、追踪 ID 和脱敏日志，不发送完整 Token 或 API Key。

7. 接入验收

使用真实测试账号逐项验证：匿名入口、A/B 两个已登录用户互不串号、过期票据刷新、错误入口拒绝、客户发消息、坐席回复、重载后历史一致、断线补拉、同一消息重试不重复。Iframe/App 还应检查宿主 Origin、账号切换、返回操作和目标设备权限。

附录 A 商城店铺与店员接入（按需启用）

商城密钥由平台管理员创建商城时签发。以下请求均由商城后端发起：

<MARKETPLACE_KEY_HEADER>: <MARKETPLACE_SERVER_KEY>

Content-Type: application/json

1. 创建或更新店铺

PUT /api/v1/marketplace/shops/{shopId}

{ "name": "店铺A", "status": "ACTIVE" }

返回 shopId、tenantId、inboxId、inboxKey、created、status。

shopId 使用商城稳定 ID；重复请求复用店铺映射。status 可为 SUSPENDED。

2. 创建或更新店员

PUT /api/v1/marketplace/shops/{shopId}/staff/{staffId}

{ "displayName": "店员A", "role": "AGENT", "status": "ACTIVE" }

店主或主管使用 SUPERVISOR，普通客服使用 AGENT；停用使用 DISABLED。

创建或恢复受套餐席位限制；角色变更或停用会撤销旧会话。

3. 店员登录会话

POST /api/v1/marketplace/shops/{shopId}/staff-session

{ "externalId": "staff-1001" }

返回 token、agent、tenantId、inboxId、expiresIn。

业务后端验证操作者和店铺归属后签发；前端使用真实店员 token 访问 console 接口。

登录不会自动上线，应通过工作台在线状态与领取会话流程完成接待。

需要复用 /console/?embedded=1 时，应对接工作台专用身份桥，店员登录与访客身份分别使用对应会话凭证。

4. 买家登录会话

POST /api/v1/marketplace/buyer-session

{ "externalId": "buyer-1001", "displayName": "买家A" }

返回 token、expiresIn:3600。

以下由买家客户端使用 Authorization: Bearer <BUYER_TOKEN>：

GET /api/v1/marketplace/buyer/threads?limit=50&offset=0

查询跨店铺私聊与已加入群聊，返回 items、total、unread、limit、offset。

items 中 kind 为 CONVERSATION 或 GROUP；total、unread 是全量值。

POST /api/v1/marketplace/buyer/shops/{shopId}/session

返回 token、identityToken、inboxKey、visitorId、tenantId、shopId。

嵌入完整聊天页面使用 identityToken；自研聊天接口使用返回的 widget token。

实时列表通知：/ws/marketplace?token=<BUYER_TOKEN>。

收到 conversation.updated 或 group.updated 后重新获取列表；断线恢复后补拉。

POST /api/v1/marketplace/buyer/logout 撤销当前买家会话及绑定聊天、群会话；其他设备不受影响。

附录 B 福利群接入（按需启用）

商城后端 Base：/api/v1/marketplace/shops/{shopId}/groups

POST Base：建群。

POST /{id}/members：批量加入成员。

POST /{id}/invite：生成邀请。

PUT /{id}/manager：设置管理员。

PATCH /{id}/policy：设置容量和发言规则。

GET Base、GET /{id}：列表与详情。

PUT /{id}/owner：转让群主。

DELETE /{id}/members/{externalId}：移除或退出。

POST /{id}/dissolve：解散群。

群管理接口的完整请求字段与响应格式由技术支持提供专项接口说明。

福利群群主和新授权管理员必须是本店有效店主或店员。买家应主动确认加入。

买家用买家 token 调用 POST /api/v1/marketplace/buyer/groups/{id}/session。

店员用客服 token 调用 POST /api/v1/marketplace/staff/groups/{id}/session。

返回 token、groupId、visitorId、expiresIn:3600，使用群会话 token 访问群消息接口。

群页面 /groups.html?groupId=<ID>&embed=1&parentOrigin=<精确宿主Origin>。

父页交接：{ "type": "tongyu.group.authenticate", "groupId": "<ID>", "token": "<GROUP_TOKEN>" }。

群消息接口使用群会话 token；访客身份票据用于一对一聊天身份初始化。

附录 C 商品与订单卡片（按需启用）

商城后端调用：

POST /api/v1/marketplace/shops/{shopId}/conversations/{id}/cards

```
{
  "senderType": "VISITOR",
  "externalId": "buyer-1001",
  "clientMessageId": "<UUID>",
  "card": {
    "kind": "ORDER",
    "id": "order-1001",
    "title": "商品名称",
    "amountMinor": 29900,
    "currency": "CNY",
    "orderNumber": "ORDER1001",
    "status": "待发货"
  }
}
```

senderType 为 VISITOR 或 AGENT；AGENT 回复需先领取接待。

kind 为 PRODUCT 或 ORDER；ORDER 必须有 orderNumber。

title 为 1～120 字；amountMinor 为非负整数，最大 9007199254740991，按两位小数最小货币单位解释。

29900 表示 299.00。currency 为三位大写币种。url、imageUrl 为可选的 http/https 地址，地址中不含用户名和密码。

商品金额、订单状态与归属以业务后端数据库为准，由业务后端构造卡片。

卡片保存发送时快照；后续订单变化需发送新卡片。卡片按约定字段展示商品及订单摘要，敏感业务信息通过原业务系统查看。

网络重试复用同一 clientMessageId。

群卡片接口为 POST /api/v1/marketplace/shops/{shopId}/groups/{id}/cards，字段 externalId、clientMessageId、card。

分享订单额外传 shareOrder:true，并由业务后端确认允许向该群分享。

附录 D 开放 API 与消息同步

普通租户后端使用客户配置单列明的租户密钥请求头（API_KEY_HEADER）：

GET /api/v1/open/me：检查当前租户与密钥。

GET /api/v1/open/conversations：会话列表。

GET /api/v1/open/conversations/{id}：会话详情。

GET /api/v1/open/conversations/{id}/messages：历史消息，支持 after / before。

POST /api/v1/open/conversations/{id}/messages：客服侧代发消息。

GET /api/v1/open/visitors：访客列表。

GET /api/v1/open/agents：客服列表。

GET /api/v1/open/stats：企业统计。

GET /api/v1/open/unread：企业未读汇总，不可直接作为单个客户未读。

GET /api/v1/open/conversations/{id}/receipts：权威已读与送达游标。

POST /api/v1/open/conversations/{id}/read：用户实际查看后上报已读。

POST /api/v1/open/conversations/{id}/delivered：设备收到后上报送达。

回执请求体：

{ "readerType": "VISITOR", "readerId": "<VISITOR_UUID>", "sequence": 12 }

sequence 必须大于 0；游标只前进。通语校验读取者与会话或企业的归属；宿主后端还须验证 readerId 对应当前已登录用户，按已验证的登录身份确定读取者。

收到实时通知不等于已读；消息按 sequence 排序，断线后按 after 补拉。

完整聊天页面已承担这些同步职责；自研聊天时需自行实现。

附录 E Webhook（按需启用）

管理员配置回调地址、密钥及订阅事件，如 message.created、message.agent、conversation.read、conversation.delivered。

回调请求携带事件、投递 ID、时间戳及签名请求头，具体名称由客户接口配置单列明。TongYu 协议对应 X-TongYu-Event、X-TongYu-Delivery、X-TongYu-Timestamp、X-TongYu-Signature；其他协议版本按该实例配置验收。

签名原文：<timestamp>.<原始请求体>。

算法：HMAC-SHA256；签名头格式 sha256=<十六进制签名>。

使用原始请求体字节验签，采用常量时间比较，检查时间窗口，并按投递 ID 幂等。

成功持久化后返回 2xx；失败会重试。游标回调取最大 sequence，防止乱序回退。

附录 F 错误处理

错误响应结构：

{ "status": 401, "code": "...", "message": "...", "timestamp": "..." }

部分错误可能没有 code，处理时结合 HTTP 状态与 message。

400：参数无效，修正参数。

401：凭证缺失、无效或过期，重新获取对应凭证。

403：权限或套餐能力不足，检查开通配置。

404：资源不存在或不属于当前企业/用户，检查映射与归属。

5xx 或网络失败：保留当前状态并有限重试；发送消息重试保持 clientMessageId。

IDENTITY_TOKEN_REQUIRED：使用后端身份票据，不直接传 externalId。

API_KEY_REQUIRED / API_KEY_INVALID：检查服务端密钥配置。

失败请求按状态码与重试策略处理，日志中的身份凭证应脱敏。

附录 G 开发分工与验收

客服系统管理员：开通企业、入口、客服、套餐与密钥，配置域名策略和 Webhook。

业务后端：验证原登录、签发短期身份、校验用户/店铺/订单归属，保管密钥。

网站/App：加载页面、交接身份、处理关闭事件、权限与账号切换。

上线前逐项验证：

1. 当前用户能发消息，客服能回复，刷新后历史保持一致。
2. 账号 A 切换账号 B 后无法看到 A 的历史；同账号重新登录保持正确身份。
3. 过期票据能重新获取；错误入口、错误企业与越权用户访问被拒绝。
4. 断网重连补回消息，重试不产生重复消息，未读与已读符合实际查看行为。
5. 图片、附件、录音与返回按钮按目标浏览器和真机验证。
6. 商城买家、店铺、店员数据隔离；停用、退出、群权限与卡片订单归属生效。
7. 检查前端安装包、URL、浏览器存储及日志不含服务端密钥。
8. 在正式接入地址完成身份、消息、权限和目标设备的全流程验收。